



Secure Development Policy

Approved and authorized by:

Anaël Greiveldinger

Chief Information Security Officer

Date: 26th of August 2024

1. Purpose

To ensure that information security is designed and implemented within the development lifecycle for applications and information systems.

2. Scope

All BW Digital applications and information systems that are business critical and/or process, store, or transmit Confidential data. This policy applies to all internal and external engineers and developers of BW Digital software and infrastructure.

3. Policy

This policy describes the rules for the acquisition and development of software and systems that shall be applied to developments within the BW Digital organization.

4. System Change Control Procedures

Changes to systems within the development lifecycle shall be controlled by the use of formal change control procedures. Change control procedures and requirements are described in the BW Digital Operations Security Policy.

Significant code changes must be reviewed and approved by Department Manager and CAB forum before being merged into any production branch in accordance with the [CHANGE MANAGEMENT PLAN](#)

Change control procedures shall ensure that development, testing and deployment of changes shall not be performed by a single individual without approval and oversight.

5. Software Version Control

All BW Digital software is version controlled and synced between contributors (developers). Access to the central repository is restricted based on an employee's role. All code is written, tested, and saved in a local repository before being synced to the origin repository.

6. Technical Review of Applications after Operating Platform Changes

When operating platforms are changed, business critical applications shall be reviewed and tested to ensure that there is no adverse impact on organizational operations or security.

7. Restrictions on Changes to Software Packages

Modifications to third-party business application packages shall be discouraged, limited to necessary changes and all changes shall be strictly controlled.

8. Secure System Engineering Principles

Principles for engineering secure systems shall be established, documented, maintained and applied to any information system implementation efforts.

At a minimum, the following secure-by-design and privacy-by-design principles shall be applied:

Secure-by-design principles:

1. Minimize attack surface area
2. Establish secure defaults
3. The principle of Least privilege
4. The principle of defense in depth
5. Fail securely
6. Don't trust services
7. Separation of duties
8. Avoid security by obscurity
9. Keep security simple
10. Fix security issues correctly

Privacy-by-design principles:

1. Proactive not Reactive; Preventative not Remedial
2. Privacy as the Default Setting
3. Privacy Embedded into Design
4. Full Functionality – Positive-Sum, not Zero-Sum
5. End-to-End Security – Full Lifecycle Protection
6. Visibility and Transparency – Keep it Open
7. Respect for User Privacy – Keep it User-Centric

Software developers are expected to adhere to BW Digital's coding standards throughout the development cycle, including standards for quality, commenting, and security.

9. Secure Development Environment

BW Digital shall establish and appropriately protect environments for system development and integration efforts that cover the entire system development life cycle. The following environments shall be logically or physically segregated:

- Production
- Test / Staging
- Development

10. System Security Testing

Testing of security functionality shall be performed at defined periods during the development life cycle. No code shall be deployed to BW Digital production systems without documented, successful test results and evidence of security remediation activities.

11. Application Vulnerability Management

Application code should be scanned prior to deployment. Patches to address application vulnerabilities that materially impact security should be deployed within 90 days of discovery.

12. System Acceptance Testing

Acceptance testing programs and related criteria shall be established for new information systems, upgrades and new versions.

Prior to deploying code, a Release Checklist MUST be completed which includes a checklist of all Test Plans which show the completion of all associated tests and remediation of identified issues.

13. Protection of Test Data

Test data shall be selected carefully, protected and controlled. Confidential customer data shall be protected in accordance with all contracts and commitments. Customer data shall not be used for testing purposes without the explicit permission of the data owner.

14. Acquisition of Third-Party Systems and Software

The acquisition of third-party systems and software shall be done in accordance with the requirements of the BW Digital Third-Party Management Policy.

15. Developer Training

Software developers shall be provided with secure development training appropriate to their role at least annually. Training content shall be determined by management but shall address the prevention of common web application attacks and vulnerabilities. The following threats and vulnerabilities should be addressed as appropriate:

- prevention of authorization bypass attacks
- prevention of the use of insecure session IDs
- prevention of Injection attacks
- prevention of cross-site scripting attacks
- prevention of cross-site request forgery attacks
- prevention of the use of vulnerable libraries

16. Exceptions

Requests for an exception to this Policy must be submitted to the CISO for approval.

17. Violations & Enforcement

Any known violations of this policy should be reported to the CISO. Violations of this policy can result in immediate withdrawal or suspension of system and network privileges and/or disciplinary action in accordance with company procedures up to and including termination of employment.

Version	Date	Description	Author	Approved by
1.0	26/08/2024	First version	A. Greiveldinger	A. Greiveldinger